KUSH Innovation Labs

ENGINEERING • SECURITY • INFRASTRUCTURE

Container Security & Codebase Audit Report

</> **Target Package:** GHCR Container / ghcr.io/kwired/hydralite:v1.0.0

🐙 **Source Repository:** https://github.com/Kwired/Hydra-Powered-Micro-PaaS

🔒 **Image Digest:** sha256:6b59e09ddb50cce2849d638050ecb16eac4a9f15106869a23a671c5f24a3e6c2

Commit Hash: 5e7cdcc07ffe835ef47ede983dc3c724f0fc76f9 (tag: v1.0.0)

Summary

Overall Status:

SECURE

Vulnerability findings:

Critical:	0
High:	0
Medium:	0
Low:	0
Info:	0

Audit metadata:

Date:	Sep 28, 2026
Scope:	Full Container & Micro-PaaS Stack
Audit phases:	4 Categories
Validation checks:	950+
Status:	CERTIFIED SECURE

Findings & Remediation Evidence

Container Base OS & Immutability Compliance (PASSED)

VERIFIED SAFE

Container Manifest / Layer Security Audit

Component	Evidence & Action Taken
Dockerfile & Layer Config	Verified hardened base python:3.11-slim-bookworm, non-root execution (USER hydralite, UID 1000), purged apt caches, and immutable image digest locking.

Risk description:

Running containers as root or with stale system packages introduces container breakout vulnerabilities, privilege escalation, and mutable layer tampering risks on production hosts.

Verification:

Container strictly drops privileges to non-root user hydralite, verifies health via an isolated HEALTHCHECK probe, and locks canonical layer state at digest sha256:6b59e09ddb50cce2849d638050ecb16eac4a9f15106869a23a671c5f24a3e6c2.

⚙ Python Dependencies & Supply Chain Audit (PASSED)

VERIFIED SAFE

Dependency / Software Composition Analysis (SCA)

Component	Evidence & Action Taken
requirements.txt (77 packages)	All 77 dependencies strictly pinned to patched upstream versions. Scanned against CVE, GitHub Advisory, and PyPA vulnerability databases.

Risk description:

Outdated or unpinned dependencies in web frameworks (FastAPI), cryptographic bindings (PyNaCl, cryptography), or WebSocket libraries can expose servers to Denial of Service or Remote Code Execution.

Audit Validation:

Scan confirmed 0 known vulnerabilities. Upgraded and pinned core frameworks: `fastapi==0.129.2`, `cryptography==46.0.5`, `websockets==16.0`, and `pycardano==0.19.1`. Zero vulnerable packages detected.

</> Hardcoded Secrets & BYOK Key Isolation (PASSED)

VERIFIED SAFE

Static Secrets Scanning & Key Governance Audit

Component	Evidence & Action Taken
Application Code & Layers	Full layer and repository regex inspection for API keys, private keys (`.sk`), seed phrases, and environment leaks.

Risk description:

Baking Cardano or Hydra signing keys into image layers or source code allows malicious actors to extract operator credentials and drain funds or hijack layer 2 channels.

Audit Validation:

Scan returned ZERO instances of hardcoded secrets. Release strictly enforces a Bring Your Own Keys (BYOK) architecture: private keys are generated locally via isolated ephemeral containers and mounted read-only (`:ro`).

Least-Privilege Isolation & Threat Boundaries (PASSED)

VERIFIED SAFE

Runtime Architecture & Network Perimeter Security

Component	Evidence & Action Taken
API & Autoscaler Architecture	Architectural review of container permission separation, CORS configuration, and network port exposures.

Risk description:

Allowing public API containers to access signing keys or exposing administrative Hydra endpoints (port 4001) or Ogmios bridge (port 1338) creates an unauthenticated attack surface.

Audit Validation:

`hydralite-api` operates under least privilege with NO signing keys mounted. Administrative ports (4001, 1338) are strictly restricted from public ingress. CORS is locked down to explicit trusted domains via `ALLOWED_ORIGINS`.

Scan coverage information

Verification Checklist

- ✓ Container Base Layer Hardened (Debian 12)
- ✓ Dependency Audit Passed (0 CVEs)
- ✓ Static Code Analysis (SAST) Passed
- ✓ Least-Privilege API Architecture Verified
- ✓ Strict CORS Origin Whitelisting Locked
- ✓ Canonical Image Digest Cryptographically Locked
- ✓ Non-Root User Execution Enforced (UID 1000)
- ✓ No Secrets or Private Keys Committed
- ✓ Bring Your Own Keys (BYOK) Enforced
- ✓ Read-Only Key Mounts for Hydra Node
- ✓ Internal Endpoints Isolated (4001, 1338)
- ✓ Automated Validation Checks Passed (950+)

SECURITY CERTIFICATION STATEMENT

This security audit was conducted using automated security testing, container layer vulnerability scanning, dependency software composition analysis (SCA), architecture threat modeling, static code analysis (SAST), and manual engineering review.

Kush Innovation Labs Engineering & Security Review certifies that the release artifact `ghcr.io/kwired/hydralite@sha256:6b59e09ddb50cce2849d638050ecb16eac4a9f15106869a23a671c5f24a3e6c2` contains **ZERO OPEN VULNERABILITIES (0 Critical, 0 High, 0 Medium, 0 Low)** and meets all security requirements for Cardano Mainnet production operation.

Issued By:

Kush Innovation Labs
Engineering & Security Review

Date: 28 September 2026

Status: CERTIFIED SECURE